

## **UNIT -3**

# **PHISHING AND IDENTITY THEFT**



# INTRODUCTION

- Method to reveal information that can be used for identity theft, i.e. It allows access to personal data.
- “**Phishing**” is the use of social engineering tactics to trick user into revealing confidential information.
- It has become universal phenomena and major threat world wide that effects not only individuals but also all industries and business that have an online presence and do online transaction through internet.
- Phishing is equal part of technology and psychology, i.e. symmetric way to exploit citizens not only by individual attacker but also by organized criminal group.
- The statistics about phishing attack/scam proves it is danger enemy among all the methods because the prime objective behind these attack is ID theft.



# PHISHING

- While checking electronic mail (E-Mail) one day a user finds a message from the bank threatening him/her to close the bank account if he/she does not reply immediately. Although the message seems to be suspicious from the contents of the message, it is difficult to conclude that it is a fake/false E-Mail. This message and other such messages are examples of Phishing - in addition to stealing personal and financial data - and can infect systems with viruses and also a method of online ID theft in various cases. Most people associate Phishing with E-Mail messages that spoof or mimic banks, credit card companies or other business such as Amazon and eBay. These messages look authentic and attempt to get users to reveal their personal information.



# HOW PHISHING WORKS

1. Planning
2. Set up
3. Attack
4. Collection
5. Identity theft and fraud



# METHODS OF PHISHING

1. Dragnet
2. Rod and reel
3. Lobsterpot
4. Gillnet



# PHISHING TECHNIQUE

1. URL (weblink) manipulation
2. Filter evasion
3. Website forgery
4. Flash Phishing
5. Social Phishing
6. Phone Phishing



# PHISHING TOOLKITS AND SPY PHISHING

- A Phishing toolkit is a set of scripts/programs that allows a phisher to automatically set up Phishing websites that spoof the legitimate websites of different brands including the graphics (i.e., images and logos) displayed on these websites.
- Phishing toolkits are developed by groups or individuals and are sold in the underground economy. These sophisticated kits are typically difficult to obtain, are quite expensive, and are more likely to be purchased and used by well-organized groups of phishers, rather than average users.



- Phishers use hypertext pre-processor (PHP) to develop the Phishing kits. PHP is a general purpose scripting language that was originally designed for web development of dynamic webpages. PHP code is embedded into the HTML source script and interpreted by a web server with the help of a PHP processor module.
- Most of the Phishing kits are advertised and distributed at no charge and usually these free Phishing kits - also called DIY (Do It Yourself) Phishing kits - may hide backdoors through which the phished information is sent to recipients (may be to the authors of Phishing kits) other than the intended users.



- Following are few examples of such toolkits:

1. **Rock Phish:** It is a Phishing toolkit popular in the hacking community since 2005. It allows techies to launch Phishing attacks. The kit allows a single website with multiple DNS names to be a variety of phished webpages, covering numerous organizations and institutes.
2. **Xrenoder Trojan Spyware:** It resets the homepage and/or the search settings to point to odd websites usually for commercial purposes or porn (exploiting through images i.e. giving false information of individual ) traffic
3. **Cpanel Google:** It is a Trojan Spyware that modifies the DNS entry in the host's file to point to its own website. If Google gets redirected to its website, a user may end up having a version of a website prepared by the phisher.



# IDENTITY THEFT

- Identity theft is a crime in which an attacker uses fraud or deception to obtain personal or sensitive information from a victim and misuses it to act in the victim's name
- According to 2010 Report published by Javelin Strategy & Research the number of "identity fraud victims were increased by 12% during 2009" and "amount of fraud increased by 12.5%". Key statistics noted about total identity frauds in the US are as mentioned below:



1. The total fraud amount was US\$ 54 billion.
2. The average amount spent by the victim was US\$ 373 and the time of 21 hours to resolve the crime.
3. In total. 11.1 million adults were found to be victims of ID theft, which amounts to 4.8% of the population being a victim of identity fraud in 2009.
4. 13% of identity frauds were committed by someone who the victim knew.
5. Online methods accounted for only 11% of ID theft in 2009.
6. Offline methodology such as stolen wallets and paperwork account for almost half (43%) of all ID thefts



- Federal Trade Commission (FTC) has provided the statistics about each one of the identity fraud mentioning prime frauds presented below.
  1. **Credit card fraud (26%):** The highest rated fraud that can occur is when someone acquires the victim's credit card number and uses it to make a purchase.
  2. **Bank fraud (17%):** Besides credit card fraud, cheque theft and Automatic Teller Machines (ATM) pass code theft have been reported that are possible with ID theft.
  3. **Employment fraud (12%):** In this fraud. the attacker borrows the victim's valid SSN to obtain a job.
  4. **Government fraud (9%):** This type of fraud includes SSN, driver license and income tax fraud.
  5. **Loan fraud (5%):** It occurs when the attacker applies for a loan on the victim's name and this can occur even if the SSN does not match the name exactly.



# **PERSONALLY IDENTIFIABLE INFORMATION(PII)**

- The fraudster always has an eye on the information which can be used to uniquely identify, contact or locate a single person or can be used with other sources to uniquely identify a single individual. PII has four common variants based on personal, personally, identifiable and identifying.
- The fraudsters attempts to steal the elements mentioned below, which can express the purpose of distinguishing individual identity:



1. Full name;
2. national identification number (e.g., SSN);
3. telephone number and mobile phone number;
4. driver's license number;
5. credit card numbers;
6. digital identity ( e.g. E-Mail address, online account ID and password);
7. birth date/birth day;
8. Birthplace;
9. face and fingerprints;



- The fraudster may search for following about an individual, which is less often used to distinguish individual identity; however these can be categorized as potentially PII because they can be combined with other personal information to identify an individual.
  1. First or last name;
  2. Age;
  3. Country, state or city of residence
  4. Gender
  5. Name of school / college / workplace
  6. Job position, grade and/or salary;
  7. Criminal record



- **Non-classified information**
- **Public information:** Information that is a matter of public record or knowledge.
- **Personal information:** Information belongs to a private individual but the individual can may share this information with others for personal or business reasons (e.g., address, telephone numbers and E-Mail addresses).
- **Routine business information:** Business information that do not require any special protection and may be routinely shared with anyone inside or outside of the business.
- **Private information:** Information that can be private if associated with an individual and individual can object in case of disclosure (e.g.. SSN, credit card numbers and other financial information).
- **Confidential business information:** Information which, if disclosed, may harm the business (e.g., sales and marketing plans, new product plans and notes associated with patentable inventions).



- **Classified information**
- **Confidential:** Information that requires protection and unauthorized disclosure could damage national security (e.g. information about strength of armed forces and technical information about weapons)
- **Secret:** Information that requires substantial protection and unauthorized disclosure could seriously damage national security (e.g.. national security policy, military plans or intelligence operations).
- **Top secret:** Information that requires the highest degree of protection and unauthorized disclosure could severely damage national security (e.g.. vital defense plans and cryptologic intelligence systems).



# **TYPES OF IDENTITY THEFT**

1. Financial identity theft
2. Criminal identity theft
3. Identity cloning
4. Business identity theft
5. Medical identity theft
6. Synthetic identity theft
7. Child identity theft



# TECHNIQUES OF ID THEFT

- Identity theft can affect all aspects of a victim's daily life and often occurs far from its victims. The attacker use both traditional, that is human-based, methods as well as computer-based techniques.
- 
1. **Human-based methods:** These methods are techniques used by an attacker without and/or minimal use of technology.
    - Direct access to information
    - Dumpster diving
    - Theft of a purse or wallet



- Mail theft and rerouting
- Shoulder surfing
- False or disguised ATMs(“skimming”)
- Dishonest or mistreated employees
- Telemarketing and fake telephone calls



**2. Computer – based technique :** These techniques are attempts made by attacker to exploit the vulnerability within existing processes and/or systems.

- Backup theft
- Hacking unauthorized access to system and database theft.
- Phishing
- Pharming
- Redirectors
- Hardware



# DIGITAL FORENSICS SCIENCE

- **Computer forensics:** It is the lawful and ethical seizure, acquisition, analysis, reporting and safeguarding of data and metadata derived from digital devices which may contain information that is notable and perhaps of evidentiary value to the trier of fact in managerial, administrative, civil and criminal investigations. In other words it is the collection of techniques and tool used to find evidence in a computer.



- **Digital forensics:** It is the use of scientifically derived and proven methods toward the presentation collection, validation, identification, analysis, interpretation, documentation and presentation of digital evidence derived from digital sources for the purpose of facilitation or furthering the construction of events found to be criminal or helping to anticipate unauthorized actions shown by disruptive to planed operations.



# THE NEED FOR COMPUTER FORENSICS

- The convergence of Information and Communications Technology (ICT) advances and the pervasive use of computers worldwide together have brought about many advantages to mankind.
- At the same time, this tremendously high technical capacity of modern computers/computing devices provides avenues for misuse as well as opportunities for committing crime. This has lead to new risks for computer users and also increased opportunities for social harm.
- The users, businesses and organizations worldwide have to live with a constant threat from hackers who use a variety of techniques and tools to break into computer systems, steal information, change data and cause havoc.



# CYBER FORENSICS AND DIGITAL EVIDENCE

- Cyber forensics can be divided into two domain:
  1. Computer forensic
  2. Network forensic
- Network forensics is the study of network traffic to search for truth in civil, criminal and administrative matters to protect users and resource from exploitation, invasion of privacy and any other crime fostered by the continual expansion of network connectivity



- Typically the evidence reside on computer systems, users created files, user protected files, computer created files and on computer networks. Computer system have the following:

1. Logical file system
2. User created files
3. Computer created files
4. Computer network



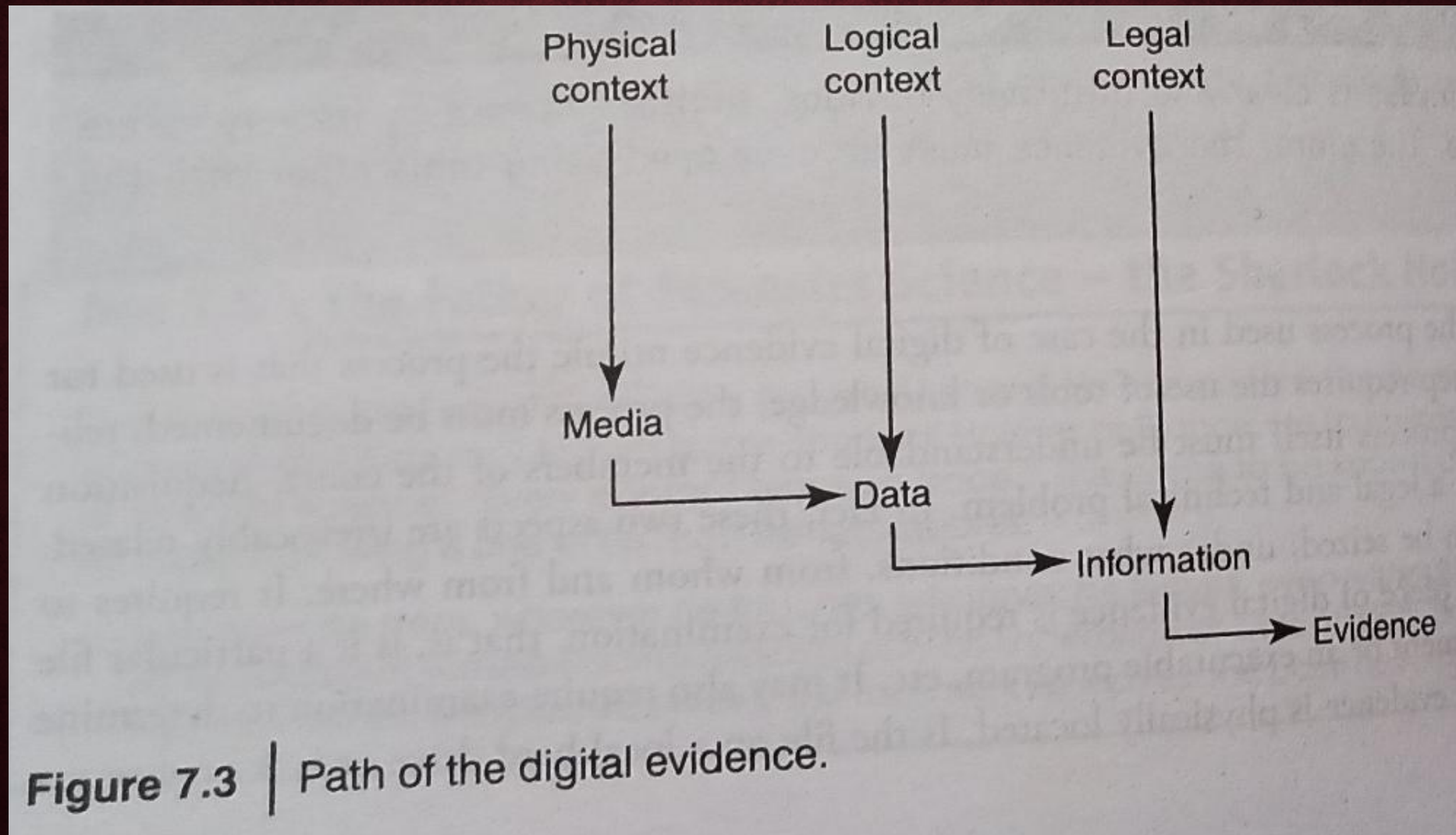
# **RULES OF EVIDENCE**

- According to the “Indian Evidence Act 1872”, “Evidence” means and includes:
  1. All statements which the court permits or requires to be made before it by witnesses, in relation to matters of fact under inquiry, are called oral evidence.
  2. All documents that are produced for the inspection of the court are called documentary evidence.



- There are number of contexts involved in actually identifying a piece of digital evidence:
  - 1. Physical context:** It must be definable in its physical form, that is it should reside on specific piece of media;
  - 2. Logical context:** It must be identifiable as to its logical position, that is, where does it resides relative to the file system.
  - 3. Legal context:** We must place the evidence in a correct context to read its meaning. This may require looking at evidence as machine language, for example ASCII.







- The path taken by digital evidence can be conceptually depicted as:
- Digital evidence originates from a number of sources such as sized computer hard drives and backup media, real-time E- Mail messages chatrooms logs, internet service providers, memory cards, digital cameras, etc.
- Similarly for evidence in regular crime it is important to isolate the potential evidence.
- A point to note is that need to unplug computer power depends on crime situation and the type of analysis required.



# DIGITAL FORENSIC LIFE CYCLE

- As per FBI's (Federal Bureau of Investigation) view digital evidence is present in nearly every crime scene.
- That is why law enforcement must know how to recognize, seize, transport and store original data evidence to preserve it for forensics examination.
- The cardinal rules to remember are that evidence:

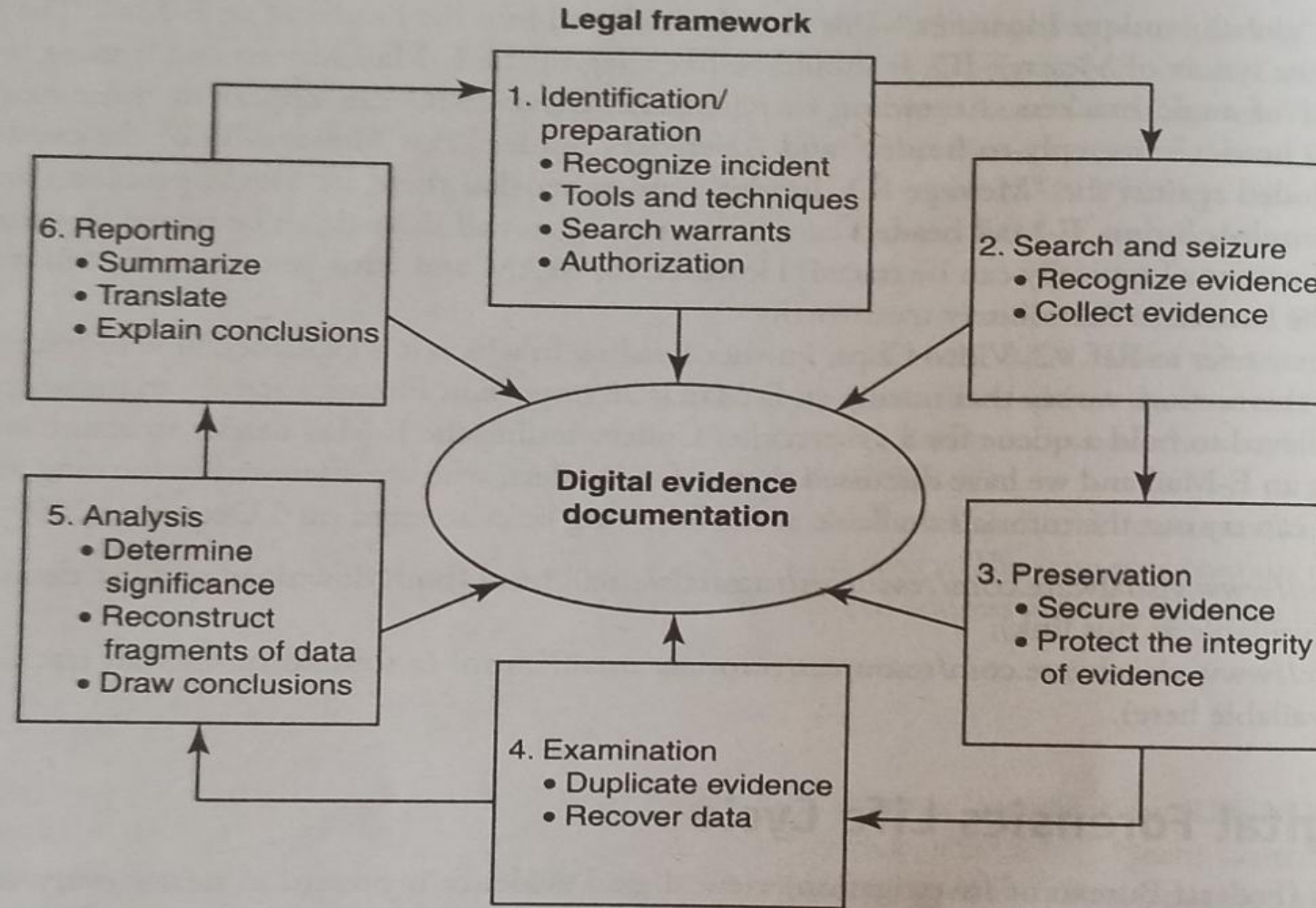


1. Is admissible
2. Is authentic
3. Is complete
4. Is reliable
5. Is understandable and believable.

- Lets now understand what is involved in digital forensics process.



# THE DIGITAL FORENSICS PROCESS



**Figure 7.5** | Process model for understanding a seizure and handling of forensics evidence legal framework.



# THE PHASES IN COMPUTER FORENSICS/ DIGITAL FORENSICS

- To mention very briefly, the process involves the process the following activities:
- 1. Prepare** : Case briefings, engagement terms, interrogatories, spoliation prevention, disclosure and discovery planning, discovery requests.
  - 2. Record** : Drive imaging, indexing, profiling, search plans, cost estimates, risk analysis.
  - 3. Investigate**: Triage images, data recovery, keyword searches, hidden data review, communication iterate.



4. **Report** : oral vs Written relevant document production, search statistics reports, chain of custody reporting, case log reporting.

5. **Testify** : Testimony preparation, presentation preparation.

- The forensic life cycle involves the following phases:



1. Preparation and identification
2. Collection and recording
3. Storing and transporting
4. Examination/investigation
5. Analysis, interpretation, and attribution
6. Reporting
7. Testifying



# **PRECAUTIONS TO BE TAKEN WHEN COLLECTING ELECTRONIC EVIDENCE**

1. Evidence preparation and identification
2. Collection and recording, preserving and transporting
3. Examination / investigation and analysis, interpretation, and attribution
4. Presentation and reporting
5. Dissemination the case



- In order to comply with the need to maintain the integrity of digital evidence, certain rules must be complied with. In general, the following principles are applicable:
  - 1. Principle 1:** No action taken by law enforcement agencies or their agents should change data held on a computer or storage media, which may subsequently be relied upon in court.
  - 2. Principle 2:** In expectational circumstances where a person finds it necessary to access original data held on a computer or on storage media that person must be competent to do so and be able to give evidence explaining the relevance and the implications of his/her actions.



**3. Principle 3:** An audit trail or other record of all processes applied to computer – based electronic evidence should be created and preserved. An Independent third party should be able to examine those processes and achieve the same result.

**4. Principle 4:** The person in-charge of the investigation has overall responsibility for ensuring that the law and these principles are adhered to.